

From AI Governance Principles to Engineering Controls

THE QUESTION

How do you translate the EU AI Act and NIST AI RMF into actionable architecture standards for engineering teams?

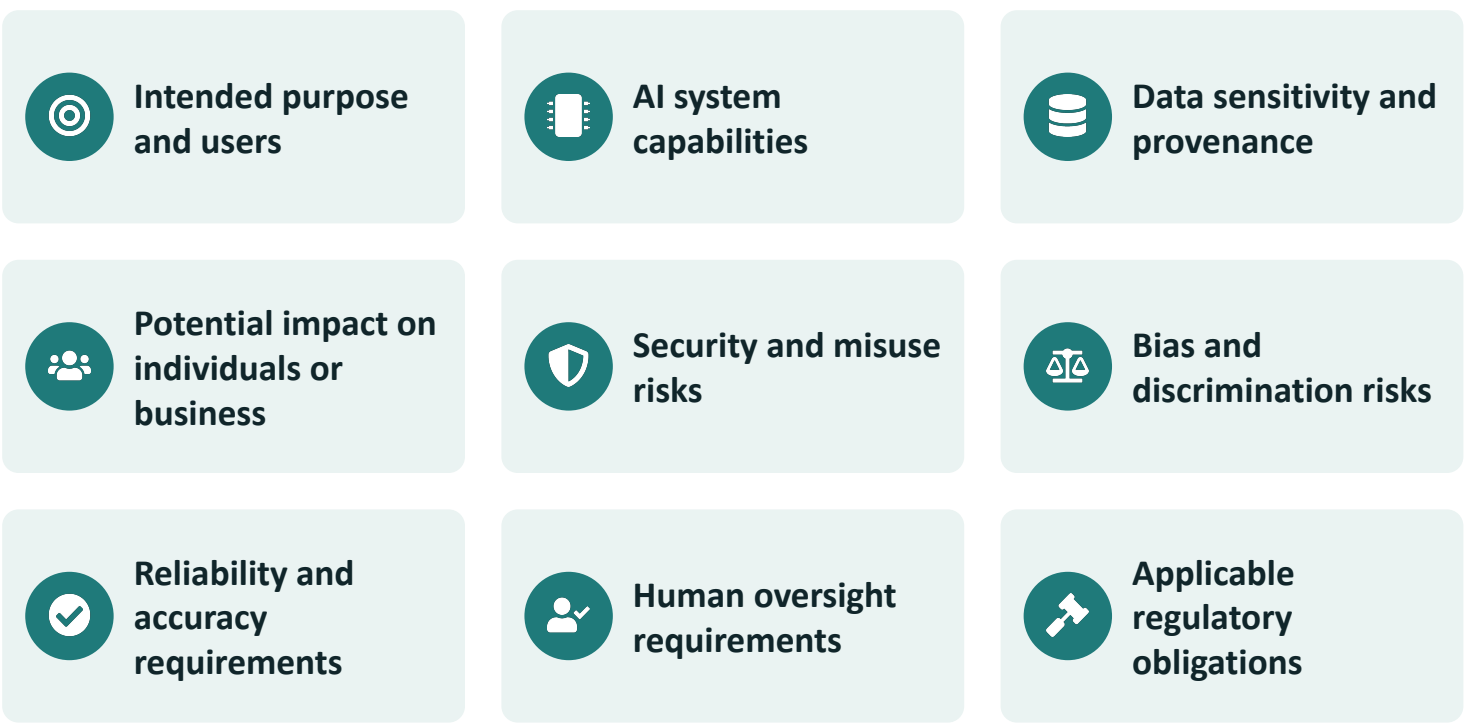
MY APPROACH



The objective is not to create compliance documentation. **It is to create repeatable, testable controls that engineering teams can implement throughout the AI lifecycle.**

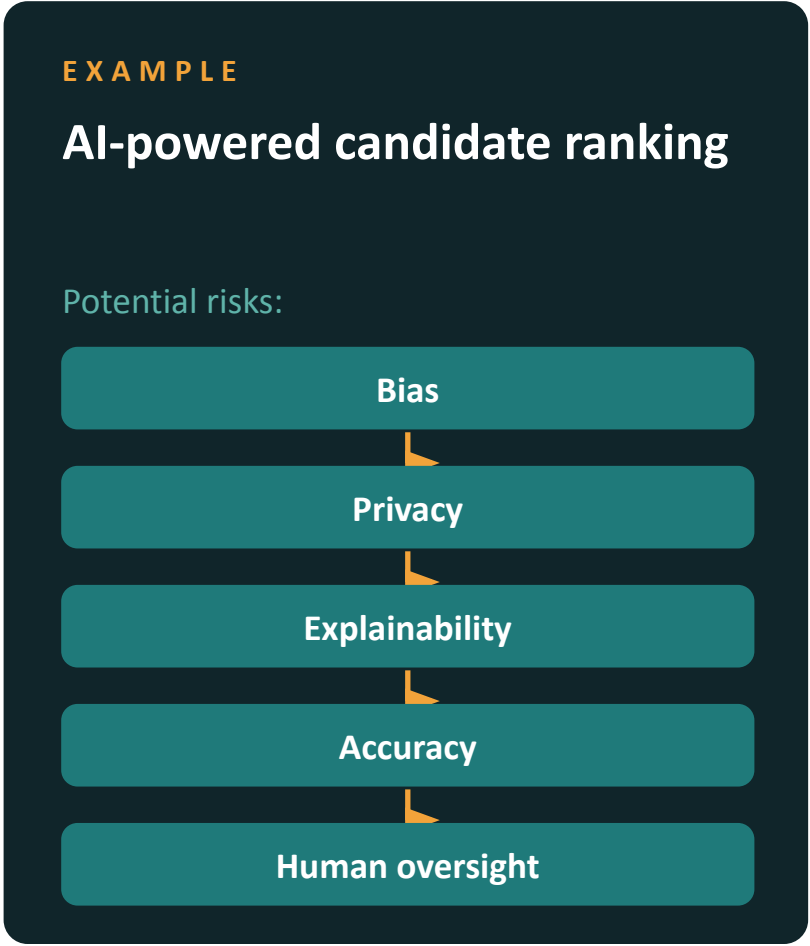
Start With Risk, Not Regulation

I begin by understanding the AI use case and its risk profile. For each use case, I assess:



This produces a risk classification and control profile for the use case.

These risks then drive the controls required during architecture and delivery.



Convert Requirements Into a Control Library

I convert governance requirements into a standardized AI control library.

Control domain	Example control	Evidence
Data governance	Data provenance and quality validation	Data lineage / validation report
Privacy	PII detection and access controls	Privacy assessment / test results
Fairness	Bias evaluation against defined criteria	Evaluation report
Transparency	AI/model system documentation	Approved system card
Human oversight	Defined human review checkpoints	Workflow / approval record
Reliability	Pre-production evaluation suite	Evaluation results
Security	Prompt injection and abuse testing	Security test results
Monitoring	Performance and risk monitoring	Monitoring dashboard
Incident management	AI incident thresholds and escalation	Incident records
Change management	Risk reassessment for material changes	Change approval
Accountability	Named system/control owner	RACI / ownership record

EACH CONTROL HAS



This prevents controls from becoming generic policy statements.

Governance-to-Architecture Traceability

THE TRACEABILITY CHAIN

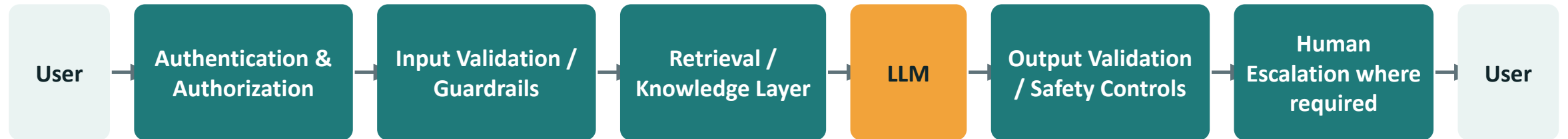


WORKED EXAMPLE

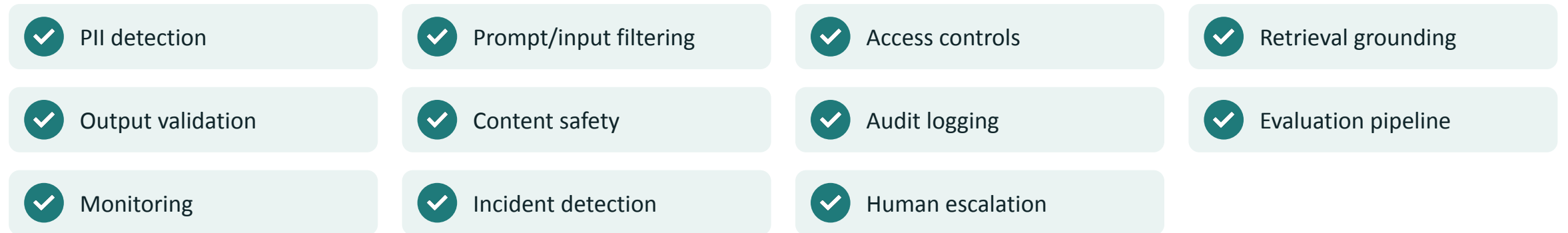
Requirement	Appropriate human oversight
Risk	Over-reliance on automated decision
Control	Human review required for defined high-impact decisions
Architecture	Human approval workflow
Technical requirement	System cannot finalize the decision without required approval
Evidence	Approval logs
Owner	Business/process owner

End-to-end traceability from regulation to implementation and evidence.

Turn Controls Into Architecture Standards



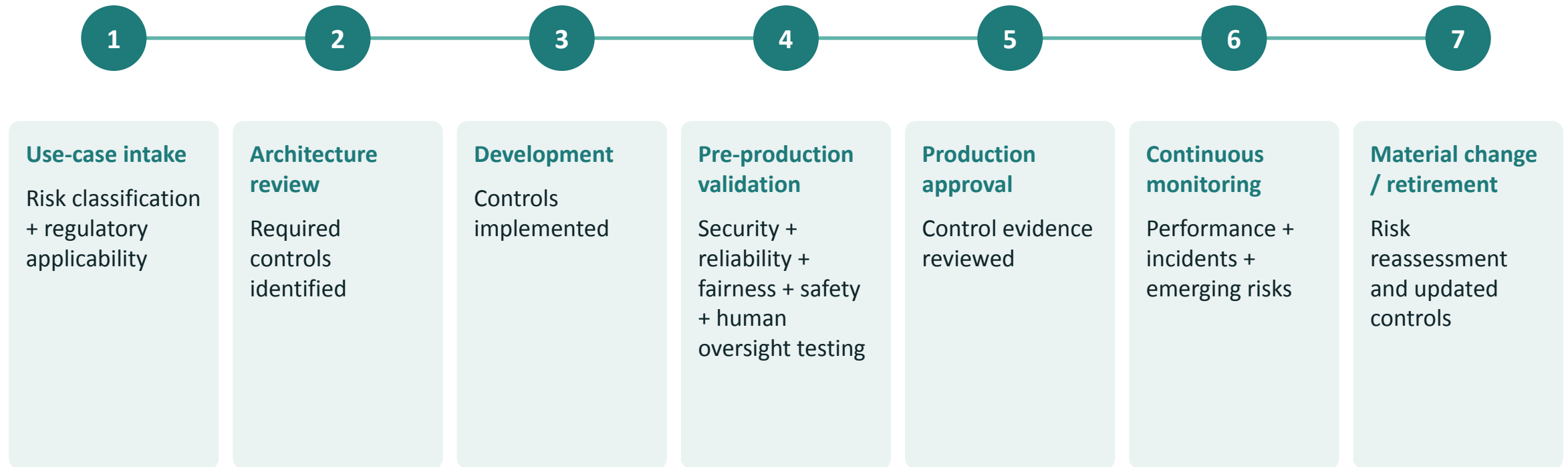
ACROSS THE ARCHITECTURE



THE PRINCIPLE

Where possible, governance requirements should become architecture patterns or platform capabilities rather than relying entirely on manual compliance activities.

Embed Governance Into the Delivery Lifecycle



This creates governance gates rather than a one-time compliance review.

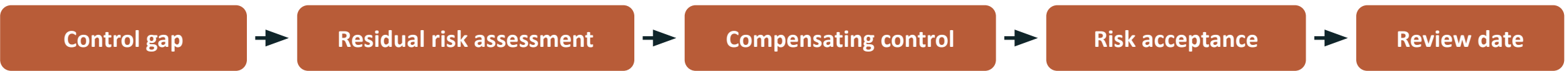
Control Effectiveness & Residual Risk

FOR EVERY IMPORTANT CONTROL

Control	What must be implemented?
Test	How do we verify it works?
Metric / Threshold	What constitutes acceptable performance?
Evidence	What proves the control operated?
Action	What happens if the threshold is breached?

EXAMPLE	
Control	GenAI output monitoring
Test	Periodic evaluation against a defined test dataset
Metric	Error/hallucination rate
Threshold	Predefined acceptable level
Evidence	Evaluation results and monitoring logs
Action	Investigation, remediation and escalation

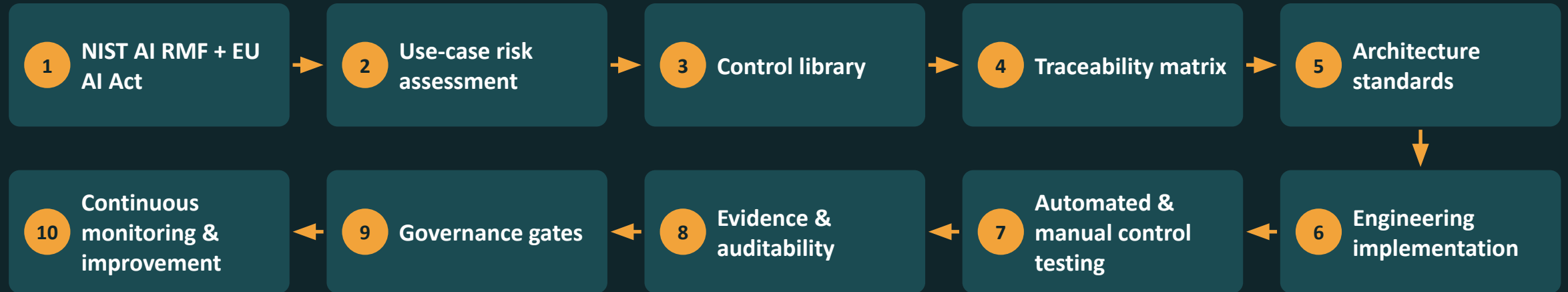
IF A REQUIRED CONTROL CANNOT BE IMPLEMENTED



This ensures that unresolved risks become explicit management decisions rather than hidden technical debt.

My Governance Operating Model

From Framework to Engineering



MY OBJECTIVE

To make AI governance actionable for engineering teams by translating principles into measurable, testable and owned controls across the AI lifecycle.

Good AI governance should enable informed risk decisions, not simply create more documentation.